

Acme Corporation

Information Security Policy

Document Classification: Internal | Version 1.0 | Owner: Chief Information Security Officer

1. Purpose and Scope

This Information Security Policy establishes the requirements for protecting the confidentiality, integrity, and availability of Acme Corporation's information assets. It applies to all employees, contractors, and third parties who access company systems, data, or networks. The policy is intended to align the organization's security practices with recognized cybersecurity frameworks and applicable regulatory requirements.

2. Access Control

Access to information systems shall be granted based on the principle of least privilege. However, due to operational convenience, standard user accounts are currently provisioned with local administrator rights by default. User accounts are created by the IT department upon receipt of a manager's email request. Passwords must be at least eight characters long. Multi-factor authentication is available but not currently enforced for remote access to internal systems.

Privileged accounts, including domain administrator accounts, are shared among members of the infrastructure team, and the shared credentials are stored in a spreadsheet on a network file share accessible to the IT department.

3. Identity and Authentication

All users are assigned a unique username. Passwords are stored by the authentication system and expire every 180 days. There is no formal account lockout threshold configured, and inactive accounts are reviewed on an ad-hoc basis rather than on a defined schedule.

4. Data Protection and Encryption

Sensitive data classified as Confidential must be protected during storage and transmission. Data transmitted over public networks is encrypted using TLS. Encryption of data at rest on employee laptops is recommended but not mandatory. Backup media are stored off-site; backups are not currently encrypted.

5. Network Security

The corporate network is protected by a perimeter firewall. Internal network segmentation between the corporate and production environments is planned but not yet implemented. Remote access is provided through a VPN. Wireless networks use WPA2 with a shared passphrase that is rotated annually.

6. Logging and Monitoring

Security-relevant events on critical servers are logged locally. Logs are retained for 30 days. There is no centralized log management or security information and event management (SIEM) solution in place, and logs are reviewed only when an incident is suspected.

7. Incident Response

Acme maintains an incident response process. Employees are instructed to report suspected security incidents to the IT helpdesk. A formal, documented incident response plan with defined roles, escalation paths, and communication procedures is under development. Post-incident reviews are conducted informally.

8. Third-Party and Vendor Management

Third parties who process company data are expected to maintain adequate security controls. Security requirements are communicated verbally during onboarding. Formal security assessments of vendors are not consistently performed, and data processing agreements are not always in place before data is shared.

9. Business Continuity

Critical systems are backed up daily. A business continuity and disaster recovery plan exists at a high level but has not been tested within the last twelve months. Recovery time objectives have not been formally defined for all critical systems.

10. Awareness and Training

New employees receive a security briefing during onboarding. Annual security awareness training is encouraged but not mandatory, and completion is not tracked. Phishing simulation exercises are not currently conducted.

11. Compliance and Review

This policy shall be reviewed annually or when significant changes occur. Exceptions to this policy require approval from the Chief Information Security Officer. Non-compliance may result in disciplinary action.